

Java Deserialization





1. Giới thiệu về Java Object Injection

1.1. Serialize

- Java cung cấp cho người dùng hàm `writeObject` để serialize các object.

writeObject

```
public final void writeObject(Object obj)
                        throws IOException
```

Write the specified object to the `ObjectOutputStream`. The class of the object, the signature of the class, and the values of the non-transient and non-static fields of the class and all of its supertypes are written. Default serialization for a class can be overridden using the `writeObject` and the `readObject` methods. Objects referenced by this object are written transitively so that a complete equivalent graph of objects can be reconstructed by an `ObjectInputStream`.

<https://docs.oracle.com/javase/7/docs/api/java/io/ObjectOutputStream.html>

1.2. Deserialize

- Để có thể đọc được dữ liệu đã được serialized từ **ObjectInputStream** ta sử dụng hàm `readObject`

readObject

```
public final Object readObject()
                        throws IOException,
                        ClassNotFoundException
```

Read an object from the `ObjectInputStream`. The class of the object, the signature of the class, and the values of the non-transient and non-static fields of the class and all of its supertypes are read. Default deserializing for a class can be overridden using the `writeObject` and `readObject` methods. Objects referenced by this object are read transitively so that a complete equivalent graph of objects is reconstructed by `readObject`.

<https://docs.oracle.com/javase/7/docs/api/java/io/ObjectInputStream.html>



1.3. Serialized data trong Java

SERIALIZED DATA TRONG JAVA

user.bin ✕

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	%φ..sr..com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C	ple.javadeserial
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51	ize.Usersi*'gçQ
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61	...L..namet..Lja
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78	va/lang/String;x
70	74	00	05	47	75	65	73	74	+							pt..Guest

FILE SIGNATURE (4 bytes)

SERIALIZED DATA TRONG JAVA

user.bin ✕

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	%φ..sr..com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C	ple.javadeserial
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51	ize.Usersi*'gçQ
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61	...L..namet..Lja
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78	va/lang/String;x
70	74	00	05	47	75	65	73	74	+							pt..Guest

CLASS NAME

SERIALIZED DATA TRONG JAVA

user.bin x

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	40	sr	com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C	ple.java	deserial	
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51	ize.UserSi	*gçQ	
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61	..L..name	..Lja	
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78	va/lang/	String;x	
70	74	00	05	47	75	65	73	74	+							pt..Guest		

TÊN THUỘC TÍNH

SERIALIZED DATA TRONG JAVA

user.bin x

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	40	sr.	com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C		ple.javadeserial	
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51		ize.Usersi*gçQ	
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61		...L..namet..LJa	
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78		va/lang/String;x	
70	74	00	05	47	75	65	73	74	+								pt..Guest	

Kiểu dữ liệu của thuộc tính



SERIALIZED DATA TRONG JAVA

user.bin ✖

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	%φ..sr..com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C	ple.javadeserial
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51	ize.Usersi*'gçQ
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61	...L..namet..Lja
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78	va/lang/String;x
70	74	00	05	47	75	65	73	74								pt..Guest

GIÁ TRỊ CỦA THUỘC TÍNH

SERIALIZED DATA TRONG JAVA

user.bin ✖

AC	ED	00	05	73	72	00	20	63	6F	6D	2E	65	78	61	6D	%φ..sr..com.exam
70	6C	65	2E	6A	61	76	61	64	65	73	65	72	69	61	6C	ple.javadeserial
69	7A	65	2E	55	73	65	72	73	A1	5C	2A	60	67	87	51	ize.Usersi*'gçQ
02	00	01	4C	00	04	6E	61	6D	65	74	00	12	4C	6A	61	...L..namet..Lja
76	61	2F	6C	61	6E	67	2F	53	74	72	69	6E	67	3B	78	va/lang/String;x
70	74	00	05	47	75	65	73	74								pt..Guest

SERIAL VERSION UID (8 bytes)

- Mỗi class trong Java sẽ có một Serial Version UID khác nhau.
- Khi deserialize, Java sẽ kiểm tra version trong serialized data và version của class đang có trên server để đảm bảo sự tương thích.



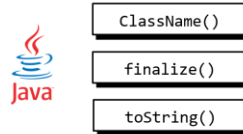
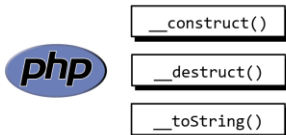
2. Khai thác Java Object Injection

- Rủi ro sẽ đến với những đối tượng deserialize untrusted data.
- Attacker có thể tận dụng các magic method, cách vận hành của OOP để tạo ra một exploit chain hoàn chỉnh.

2.1. Java's Magic method

JAVA'S MAGIC METHOD

TƯƠNG TỰ NHƯ BÊN **PHP** CÓ **MAGIC METHOD**
TRONG **JAVA** CŨNG CÓ NHỮNG HÀM TƯƠNG TỰ



2.2. Tùy chỉnh quá trình Serialize và Deserialize

TÙY CHỈNH QUÁ TRÌNH SERIALIZE / DESERIALIZE

SERIALIZE/DESERIALIZE MẶC ĐỊNH

[illegible]

CHO PHÉP LẬP TRÌNH VIÊN TÙY CHỈNH QUÁ TRÌNH
SERIALIZE / DESERIALIZE

- ☐ Nén dữ liệu
- ☐ Encrypt
- ☐ Tăng performance



TÙY CHỈNH QUÁ TRÌNH SERIALIZE

```
public class User implements Serializable {
    private String name;
    public User(String name) {
        this.name = name;
    }

    private void readObject(ObjectInputStream in) throws ClassNotFoundException, IOException {
        this.name = in.readUTF();
    }

    private void writeObject(ObjectOutputStream out) throws IOException {
        out.writeUTF(name.toUpperCase());
    }
}
```

LẬP TRÌNH VIÊN CHỈ CẦN VIẾT LẠI METHOD `writeObject()` & `readObject()` CỦA CLASS.



KHI THỰC HIỆN SERIALIZE HOẶC DESERIALIZE, JAVA SẼ **TỰ ĐỘNG** GỌI ĐẾN CÁC METHOD NÀY.

3. Tổng kết

